Experiment 8: Scan a system or web app for common vulnerabilities

Use vulnerability scanning tools to check for issues like outdated software, default passwords, or misconfigurations. Tools like OWASP ZAP (passive scan mode) can be safely used.

Background/Theory

Vulnerability scanning is a process used to identify security weaknesses in a web application or system. It helps detect issues such as misconfigurations, insecure headers, injection flaws & missing protections.

OWASP ZAP (Zed Attack Proxy) is an open-source penetration testing tool widely used for scanning web applications. It supports:

- Passive scanning: analyse traffic without modification request (safe)
- Active scanning: sends attack payloads to find vulnerabilities (aggressive)

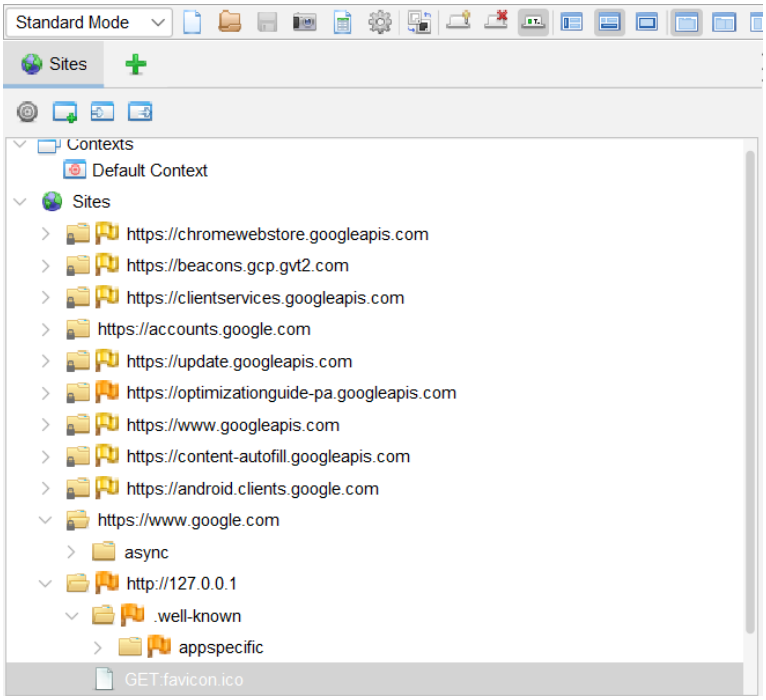
Methodologies

Steps:

1. Open the login page: http://127.0.0.1/web/connect_VLP.php
2. Then, download the OWASP ZAP and start it.
3. In ZAP, select Manual Explore from the Quick Start screen.
4. Enter the URL of the login page & select the chrome browser, then launch browser & the session open proxy through ZAP.
5. Interact with the login form.
   - Test input used: ' OR 1'='1 (to check the injection behaviour)
   - Inspect Developer Tool
     1. The browser inspect is opened on the login page.
     2. The Sources tab displays JavaScript files used by the application.
     3. This shows that client-side code is accessible to users.
     4. No obfuscation or protection is applied to the code.
     5. The main issue is still server-side validation, not client-side code.

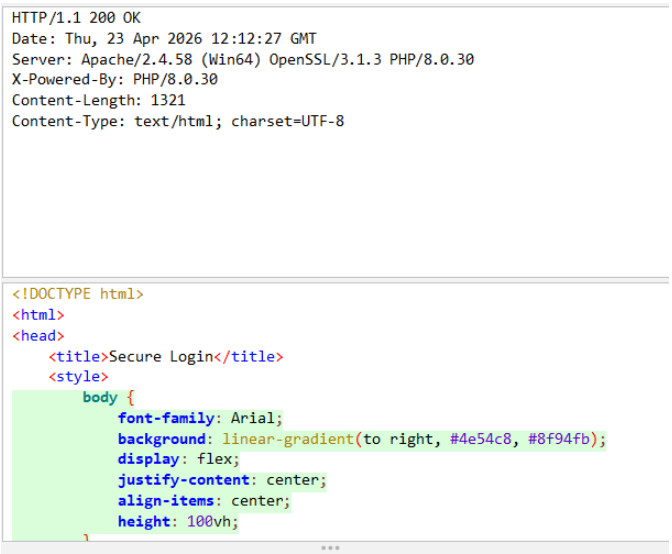
6. Check the Site Panel

- Shows captured URLs & domain during scan
- Target site (127.0.0.1) & paths are listed
- Indicates ZAP is mapping the application



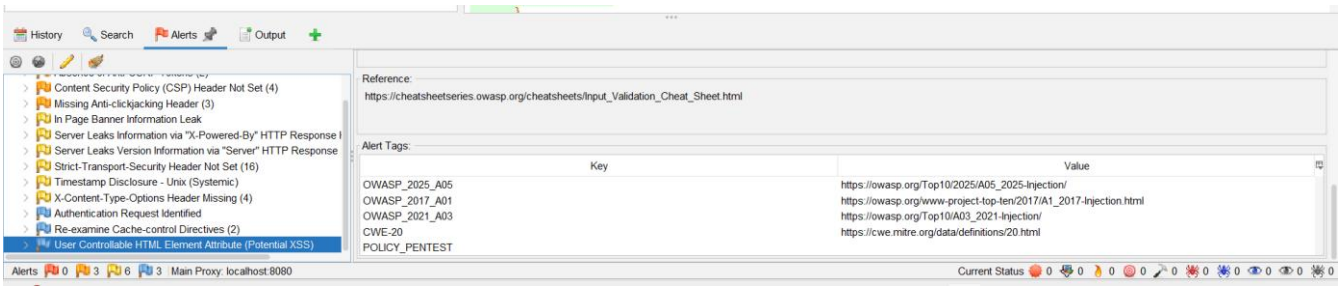
7. Open response panel

- Shows HTTP response (200 OK) & server details
- Reveals Apache/PHP via headers
- Indicates information disclosure



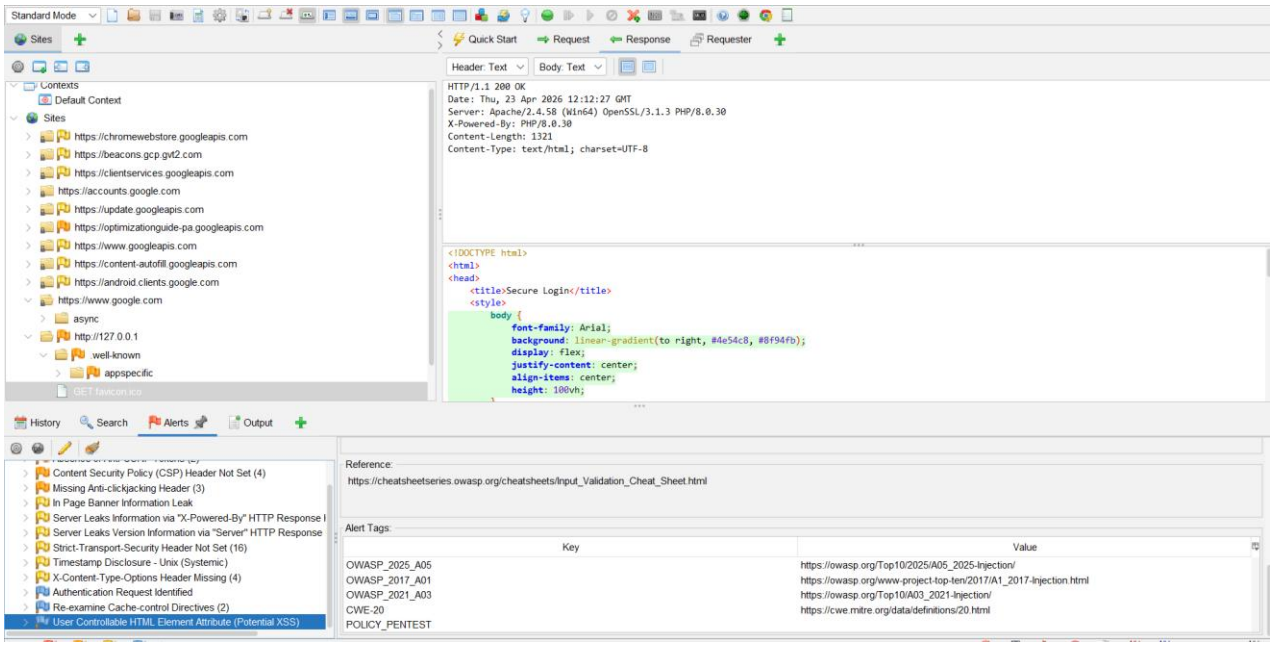
8. Go to Alert Tab

- Display detected vulnerabilities (CSP, CSRF, headers)
- Potential XSS is highlighted
- Shows multiple security issues



9. Review the complete ZAP interface

- Analyse all results together (sites, alerts, responses)



Observation

- The login page traffic was successfully captured using OWASP ZAP in passive mode.
- Multiple vulnerabilities were detected such as SQL injection (login bypass), missing CSRF token & insecure headers.
- Server details like Apache & PHP version were exposed in the response headers.
- The application lacked proper input validation & security configuration.

- Additional issues like potential XSS & hidden endpoints were also identified.

Result:

- The passive scan of the developed login page using OWASP ZAP successfully identified multiple security vulnerabilities.
- These include SQL injection, missing CSRF protection, insecure headers and information disclosure.
- The experiment shows that the application is vulnerable & required proper input validation & security configuration.